6

CRA Incident Simulation

Çıktı: Incident Workflow

Ad Soyad **Muhammed Salih Atiç** | Grup | Tarih **28.10.2026**

Senaryo: Saat 10:15. Servis hesabında yetkisiz erişim tespit edildi. PLC konfigürasyonu değişmiş olabilir. Makine hâlâ çalışıyor. Vardiya sorumlusu sizsiniz. *(Bu föyde: müşterinin trafo fabrikasında FADA uzak servis hesabıyla oturum açılmış; otonom araç 350 t'luk trafoyu test alanına taşıyor.)*

Kavram: Bir olayda en değerli iki şey **zaman ve kanıttır**. CRA'nın 24s / 72s / 14 gün yükümlülükleri, iyi bir müdahale akışının doğal kilometre taşlarıdır — ezber değil. *(CRA bildirimi ürün üreticisinin, yani FADA'nın yükümlülüğüdür; vardiya sorumlusu bilgiyi ve kanıtı sağlar.)*

Görev — zaman çizgisini doldurun

1. 10:15 — ilk 15 dk: Kimi ararsınız? İlk üç eyleminiz?

   Ararım: tesis OT/BT güvenlik sorumlusu, bakım şefi ve İSG uzmanı, FADA servis/ürün güvenliği hattı.
   İlk üç eylem: (1) **Önce emniyet:** aracı kontrollü biçimde güvenli duruşa al (dur, fren, yük hidrolik olarak kilitli), çevresini boşalt; konfigürasyonu güvenilmez kabul et. (2) Uzak erişimi kes: jump server/VPN oturumunu sonlandır, conduit'i kapat. Aracı resetleme veya enerjisini kesme, kanıt silinmesin. (3) Saat ve gözlemleri yazan bir olay kaydı aç.

2. İlk 2 saat: Emniyet güvende mi? Neyi korursunuz (kanıt!)? Hangi hesap kapatılır?

   Emniyet: Safety PLC program checksum'unu ve tarayıcı koruma alanlarını onaylı referansla karşılaştır. Doğrulanana kadar araç kilitli (etiketleme/kilitleme) kalır; filodaki diğer araçlar da kontrol edilir.
   Kanıt: PLC'nin mevcut programının üzerine yazmadan alınmış kopyası, jump server oturum kayıtları, VPN/MFA ve güvenlik duvarı logları, filo sunucusu komut geçmişi, araç olay/hata kayıtları. Saatler senkron tutulur.
   Hesap: ele geçirilen servis hesabı devre dışı bırakılır, oturumları iptal edilir. Diğer tüm servis hesaplarının parolaları ve anahtarları yenilenir.

3. 24 saat — CRA erken uyarı: Hangi bilgi hazır olmalı?

   FADA, ENISA'nın tek raporlama platformu üzerinden ilgili CSIRT'e erken uyarı gönderir. Hazır olması gerekenler: ürün kimliği (model, seri no, yazılım/firmware sürümü), olayın kötü niyetli eylemden kaynaklandığı şüphesi, aktif istismar edilen bir açık olup olmadığı, etkilenen müşteri ve ülkeler, alınan ilk önlemler. *Türkiye'de ayrıca 7545 sayılı Kanun kapsamında Siber Güvenlik Başkanlığı'na gecikmeksizin bildirim değerlendirilir.*

4. 72 saat — CRA bildirim: Kök neden, etki, önlem — kim ne yapıyor?

   Kök neden (ilk değerlendirme, ör. çalınan parola + MFA eksikliği) → FADA servis/yazılım ekibi analiz eder. **Etki** (kaç araç, emniyet konfigürasyonu değişti mi, fiziksel olay oldu mu) → müşterinin OT ekibi saha verisini sağlar. **Önlemler** (MFA, varsayılan kapalı erişim, yama) → FADA ürün güvenliği sorumlusu bildirimi yazar; yönetim ve hukuk onaylar; müşteri bilgilendirilir.

5. 14 gün — son rapor: Hangi loglar/kayıtlar korunmuş olmalı?

   Uzak erişim oturum kayıtları ve kimlik doğrulama logları · güvenlik duvarı/VPN logları · PLC program sürümleri (öncesi/sonrası) ve değişiklik geçmişi · Safety PLC checksum ve tarayıcı konfigürasyon kayıtları · filo yönetim komut logları · araç olay kayıtları · olay zaman çizelgesi, verilen kararlar ve düzeltici önlemin kanıtı. *Not: CRA'da son rapor; açıklar için düzeltici önlemden sonraki 14 gün, ciddi olaylar için 72 saatlik bildirimden sonraki 1 ay içinde verilir.*

En sık hata: "Resetleyip devam edelim" — o düğme, kanıtı sonsuza dek siler. Önce emniyet, hemen sonra kanıt.

Bu föyün çıktısı **Incident Workflow** → Evidence Pack **EP 13 Incident Response** başlığına oturur.